LabTrail

A Patient-Controlled Longitudinal Lab Record

Solution Design Report — Assignment 2: Solution Architecture and Design

Author: Renee Raven **Email:** rraven2021@fau.edu **Course:** CEN 5035 — Software Engineering

Instructor: Dr. Fernando Koch **Date:** 10/10/26 *(Cryptographic & Security Revision)*

---

1. Executive Summary

1.1 The Business Problem

People managing chronic or multi-specialty health conditions rarely receive laboratory work from a single organization. Within a single year, one patient may have specimens drawn at an independent reference laboratory, a hospital inpatient or outpatient laboratory, and a specialist clinic. Each organization releases results through an isolated portal, using distinct document layouts, measurement units, analyte naming conventions, and reference intervals. Patients accumulate a fragmented folder of static documents rather than a longitudinal clinical record.

Consequently, **a single analyte cannot be evaluated across time**. A biomarker trending steadily upward or downward across four draws at three laboratories appears as four disconnected numbers. Longitudinal trends and early clinical signals are easily missed by both patients and clinicians. Meanwhile, explanatory context—such as starting or adjusting a medication, changing diet, experiencing an acute illness, or altering physical activity—exists only in the patient's memory and is reconstructed imperfectly during brief appointments. Treating clinicians see only what resides in their local electronic health record (EHR) plus whatever loose documents the patient brings and recalls.

1.2 Proposed Solution Direction

LabTrail is a patient-controlled longitudinal laboratory record built as a zero-knowledge hosted service with a trusted client (`Z1`). Patients manually import their existing laboratory reports (PDFs or images). A controlled Document Intelligence pipeline classifies each document, extracts individual result rows as *candidates* alongside page coordinates, normalizes units against versioned conversion tables, and maps analytes to standard codes. Every candidate passes through an explicit **human-in-the-loop review queue**: only values explicitly accepted or corrected by the patient enter the longitudinal record.

Every accepted value remains permanently linked to its immutable source document and page region. Patients can record dated context notes on the same timeline and issue **scoped, time-bounded, revocable share grants** to named recipients (such as treating clinicians). Share bundles are prepared, redacted to flattened text-free raster images, and encrypted directly on the patient's device using **AES-256-GCM** with a **2-of-2 XOR key split**, ensuring the hosting operator can enforce access policy and 5-second revocation without ever reading patient health information.

1.3 Architectural Positioning & Capability Boundary

LabTrail follows the **Document Intelligence Agent Pipeline** pattern (`Classify → Extract → Normalize → Assemble → Verify`), enforcing a strict structural separation between non-deterministic AI extraction (`Z4`) and deterministic normalization, presentation, and access enforcement (`Z1` / `Z3`). Generative AI is restricted exclusively to document classification and candidate row extraction; it is prohibited from interpreting values, diagnosing conditions, scoring risk, or recommending clinical actions.

2. Problem Context, Stakeholders, and Capability Boundary

2.1 Discovery Basis & Operating Context

The problem context derives from direct clinical nursing experience and personal family care advocacy across distributed outpatient and acute care settings:

1. **Acute Care Continuity Gap:** A patient admitted to an inpatient unit reported a critical recent result performed at an external reference laboratory not interfaced with the admitting hospital's EHR. Because no verifiable copy was immediately accessible, treatment decisions were delayed and blood draws were unnecessarily repeated.
2. **Multi-Specialty Chronic Care Fragmentation:** Managing multiple chronic conditions across primary care and subspecialists produced dozens of disconnected reports from multiple laboratories over two years. During specialist consultations, significant appointment time was consumed manually cross-referencing paper printouts rather than evaluating longitudinal trends and medication adjustments.

The operating environment is distributed outpatient care where laboratory testing occurs across unaffiliated organizations over multi-year horizons.

2.2 Current Workflow Reference Model

Figure 1 — Scenario Reference Diagram of the Current Workflow

1. **TRIGGER:** Results released by multiple organizations (Reference lab, hospital lab, specialist office, DTC).
2. **INFORMATION CHANNELS:** Separate portals, PDFs, paper, fax. *(Risk Marker 1: Same test, differing units & reference intervals)*
3. **PATIENT MANUAL ASSEMBLY:** Downloads, prints, files in folders or photo albums. *(Risk Marker 2: No ordered series; trend invisible. Risk Marker 3: Sharing is all-or-nothing, permanent, unlogged)*
4. **APPOINTMENT HANDOFF:** Loose papers handed over; sequence recalled verbally. *(Risk Marker 4: Explanatory context recalled imperfectly)*
5. **CLINICIAN REVIEW & DECISION AUTHORITY:** Reads local EHR + arriving printouts. *(Risk Marker 5: Outside results lack verifiable provenance)*
6. **OUTCOME TODAY:** Decisions made on partial history. *(Risk Marker 6: Repeat testing cost, visit delay, missed signals)*

2.3 Capability Boundary

Figure 2 — Capability Boundary

Inside the Capability (Software Enforced)	Outside the Capability (Explicitly Prohibited)
• Manual import & registration of PDF/image reports • Candidate extraction, analyte coding & unit normalization • Duplicate detection & cross-lab comparability flagging • Patient review queue: accept, correct, reject • One-action provenance link to source page & region • Dated patient context notes on analyte timelines • Deterministic single-analyte timeline & export • Scoped, expiring, revocable grants & immutable access log • Read-only recipient view with flattened redacted pages *Patient Authority: Decides what enters record & who sees it.*	• Clinical interpretation of any laboratory value • Diagnosis, cause attribution, prognosis, or risk scoring • Treatment, dosing, or follow-up testing recommendations • Clinical alerting requiring medical response • Automated portal/EHR scraping or write-back • Patient-clinician messaging • Imaging, pathology narratives, or genomic data • Ordering, billing, or appointment scheduling *Clinician Authority: Solely interprets results & directs care.*

2.4 Stakeholders & Authority Boundaries

ID	Stakeholder	Primary Goal	Authority Boundary
SH-01	**Patient**	View one unified history per analyte, capture context, and govern sharing precisely.	**Sole authority** over record acceptance and access grants. **No authority** to request clinical interpretation from software.
SH-02	**Treating Clinician**	Review outside results rapidly with verifiable source, units, intervals, and comparability flags.	**Sole authority** to interpret results and make clinical decisions. **No authority** to edit records or extend access.
SH-03	**Caregiver / Proxy**	Assist with report imports, review preparation, and visit sharing under explicit delegation.	Operates strictly within revocable permissions explicitly granted by **SH-01**.
SH-04	**Source Laboratory**	Accurate attribution of reported values, units, reference intervals, and assay notes.	Authoritative over original report content; source artifacts are immutable (`C-04`).
SH-05	**Product Steward**	Ensure deterministic normalization and comparability rules remain accurate and versioned.	Governs versioned reference data (`NFR-17`). **Zero authority** to view patient records.
SH-06	**Privacy Reviewer**	Verify zero-knowledge custody, redaction integrity, and non-SaMD boundary adherence.	Authority to block any release violating privacy rules or Figure 2 (`NFR-16`).

3. Requirements Baseline & Architectural Constraints

3.1 Functional Requirements (FR-01 – FR-24)

ID	Functional Requirement	Validation Criterion / Expected Evidence
FR-03	Extract candidate result rows containing analyte name, value, unit, reference interval, specimen type, abnormal flag, plus page number and bounding box.	Labeled evaluation run meets `NFR-09` accuracy thresholds; every candidate carries page/bbox or explicit `region_unavailable` .
FR-05	Resolve candidate values deterministically: (1) direct conversion; (2) converted via versioned factor; (3) retained in original unit and excluded from canonical series.	Known pairs convert accurately; unconvertible mass/molar pairs remain in original units in a separate non-plotted section with reason stated.
FR-08	Route low-confidence, internally inconsistent, or conflicting extractions to patient review; prohibit auto-acceptance.	Audit log confirms 100% of accepted values have an explicit patient acceptance event.
FR-09	Allow patient to accept, correct, or reject candidates. Corrected values carry `CORRECTED_BY_PATIENT` provenance.	Patient can decrypt prior/new values; no plaintext values enter server audit envelope.

ID	Functional Requirement	Validation Criterion / Expected Evidence
FR-14	Allow patient to create share grants scoped to a recipient, explicit analyte list, date range, and mandatory expiration.	Attempt to create unscoped/non-expiring grant is rejected; recipient sees strictly the granted slice.
FR-15	Allow patient to revoke any active grant, destroying server-held key material and denying access within 5 seconds.	Timed test confirms `Server_Share` destruction and `403` denial within ≤ 5.0 s.
FR-19	Render source pages to recipients as flattened raster images with ungranted result rows masked and labeled `REDACTED`.	Single-analyte grant yields a flattened PNG with other rows masked; text extraction yields zero ungranted tokens.

3.2 Non-Functional Requirements (NFR-01 – NFR-20)

ID	Category	Measurable Requirement
NFR-01	Privacy	Zero disclosure of record data except via active patient-authorized grants; zero secondary use.
NFR-02	Privacy	Default-deny access; grants restrict access strictly to selected analytes and date range (expiration ≤ 5 years).
NFR-03	Security	Client-side encryption of records and share bundles using **AES-256-GCM** prior to upload; TLS 1.3 transport.
NFR-08	AI Conditions	Generative models execute only in Classify/Extract; model ID, version, and prompt hash logged; zero auto-acceptance.
NFR-09	AI Quality	Extraction accuracy achieves ≥ 98% on PDFs and ≥ 90% on scanned reports before release.
NFR-12	Revocation	Revocation takes effect within ≤ 5.0 s measured from server acknowledgment (t_{ack}).
NFR-20	Crypto	AES-GCM AAD binds canonical public metadata (grant_id, schema_version); volatile key buffers are zeroized.

3.3 Architectural Constraints

- **C-02 (Immovable Clinical Authority):** Software never characterizes, scores, or interprets clinical meaning.
- **C-05 (Manual Import Only in v1):** Zero runtime dependencies on external EHR or laboratory portal APIs.
- **C-08 (Zero-Knowledge Custody & Split-Key Sharing):** `Z3` backend cannot read patient records or share bundles. Encrypted under a 2-of-2 XOR key split (`Recipient_Share = Grant_Key ⊕ Server_Share`). `Z3` stores `Server_Share` and ciphertext.

4. Domain Model & Core Entities

Figure 4 — Core Domain Model Definitions

- **PatientAccount (Z1):** Manages UUID, KDF salts, wrapped master keys, and recovery states.
- **SourceReport (Z1):** Holds immutable file blobs, hashes, metadata, and matched identity.
- **CandidateExtraction (Z1):** Holds raw AI outputs, bounding boxes (normalized [0,1]), confidence scores, and extraction metadata. Status isolated from accepted record.
- **AcceptedObservation (Z1):** Canonical deterministic outcomes. Snapshots the bounding box and exact source page. Lifecycle status distinct from review provenance (`AS_EXTRACTED` vs `CORRECTED_BY_PATIENT`).
- **ClientShareGrant (Z1):** Holds patient's actual plaintext intent: recipient email, explicit analyte scope, and date ranges.
- **GrantRecord (Z3):** Holds operational metadata only: `grant_id` , cryptographic `Server_Share` , IV nonce, and expiry. Contains *zero* clinical scope or plaintext recipient names.
- **AuditEvent (Z3):** Immutable hash-chained ledger. Patient-entered review details are encrypted on Z1; no plaintext clinical values enter the server audit envelope.

5. Architectural Overview & Trust Zones

5.1 Four-Zone Trust Architecture

Figure 3 — System Architecture and Trust Zones

- **Zone 1 (Z1) — Trusted Client:** Holds the Patient Master Key (PMK), executes client-side PDF rasterization and black-box redaction, runs deterministic normalization, performs AES-256-GCM encryption and 2-of-2 XOR key splitting.
- **Zone 2 (Z2) — Edge Gateway:** Terminates TLS 1.3, enforces MFA, validates recipient second factors, and routes authenticated requests.
- **Zone 3 (Z3) — Blind Core Storage:** Stores encrypted patient vaults, append-only hash-chained audit logs, and `GrantRecord` entries containing the `Server_Share` . Z3 has zero cryptographic capability to decrypt patient records.
- **Zone 4 (Z4) — Ephemeral Extraction Pipeline:** Receives a transient decryption capability during active upload, executes Document Intelligence, returns Candidate JSON to Z1, and immediately purges volatile memory.

6. Assumptions, Open Questions, and Risk Register

ID	Risk Description	Severity	Architectural Mitigation
R-03	Feature creep into clinical interpretation / SaMD territory.	High	Hard architectural exclusion, automated prohibited-intent filter, privacy reviewer release gate (`NFR-16`).
R-07	Server breach exposes stored health records.	High	Zero-knowledge client-side AES-256-GCM encryption (`C-08`), TLS 1.3, append-only audit.
R-09	Recipient source page leaks ungranted rows via text layer.	High	Flattened PNG rasterization with zero text layer (`FR-19`); full page withholding on unreliable bbox (`FR-20`).
R-10	Post-retrieval retention: Recipient retains data after patient revokes grant.	High (Residual)	Revocation destroys `Server_Share` within ≤ 5.0 s. Risk mitigated by narrow grant scoping and mandatory verbatim patient consent disclosure prior to sharing.

7. Detailed Design & Cryptographic Protocol

7.4 Deterministic Processing Rules

- **Comparability Rule (FR-07):** Adjacent accepted values receive a discontinuity marker whenever:

$$source_lab(v_{i-1}) \neq source_lab(v_i) \lor unit_basis(v_{i-1}) \neq unit_basis(v_i) \lor ref_interval(v_{i-1}) \neq ref_interval(v_i) \lor method_note(v_{i-1}) \neq method_note(v_i)$$

7.5 Cryptographic Design & Key Management (C-08)

1. Direct Authenticated Encryption (Z1): The scoped `ShareBundle` is serialized and encrypted directly under a fresh 256-bit `Grant_Key` :

```
Grant_Key ← {0,1}^256
IV ← {0,1}^96
bundle_ciphertext = AES-256-GCM-Enc(Key=Grant_Key, IV=IV, Plaintext=plaintext_bundle, AAD=AAD)
```

2. 2-of-2 Information-Theoretic Key Split (Z1): The key is split to ensure Z3 blind storage:

```
Server_Share ← {0,1}^256
Recipient_Share = Grant_Key ⊕ Server_Share
```

`Recipient_Share` is placed in the URI fragment (`#...`), ensuring HTTP-request isolation from the server.

3. Five-Second Revocation Clock & Bounded Leases (NFR-12): Revocation window begins at timestamp t_{ack}. `CMP-09` destroys the `Server_Share`. Distributed enforcement nodes must validate a bounded revocable lease satisfying:

$$\texttt{Lease_TTL} + \Delta_{\texttt{clock_skew}} < 5.0 \text{ s}$$

7.5.6 Mandatory Verbatim Patient Consent Disclosure (R-10)

Prior to confirming any grant creation, the UI presents the following verbatim notice:

> **Patient Consent & Sharing Disclosure:**
> 1. **Scoped & Masked Sharing:** Only the specific laboratory analytes and date range you selected are included. Source report pages are converted into flattened images with all other test results permanently masked out.
> 2. **How Revocation Works:** Within 5 seconds of revocation, LabTrail destroys its half of the decryption key, permanently blocking all future access.
> 3. **What Revocation Cannot Undo:** If the recipient has already opened the link while active, they may have viewed, printed, or saved a copy on their own device. Revoking stops future access only.

8. Implementation Plan & Verification

8.1 Seven-Increment Implementation Plan

- **Inc 0 — Foundation & Crypto Vault:** `CMP-01` (PMK, AES-256-GCM, 24-word recovery), `CMP-08` encrypted blob store, `CMP-10` hash-chained audit log.
- **Inc 1 — Ephemeral Extraction & Review Loop:** `Z4` pipeline, candidate extraction, bounding boxes, patient accept/correct/reject workflows.
- **Inc 2 — Deterministic Normalization:** Unit conversions, duplicate detection, comparability flagging, deterministic timelines.
- **Inc 3 — Split-Key Sharing & Flattened Redaction:** HTML5 Canvas flattened PNGs, 2-of-2 XOR split, `Z1-R` viewer decryption.
- **Inc 4 — Revocation & Retraction:** Authoritative lease engine (≤ 5.0 s), atomic `Server_Share` destruction, post-share value retraction.
- **Inc 5 — Full Record Portability:** JSON/CSV export bundler.
- **Inc 6 — Hardening & Audit:** WCAG contrast, regulatory boundary review.